

# Business Risk Management

Prepared by: Dorathy Christopher

Client: Safempire Inc.

Date: June 30, 2026

## Qualitative Risk Assessment

### 1.1 Asset Identification

The SafeConnect platform depends on several interconnected assets, each carrying a distinct risk profile. Protecting them requires understanding not just their technical function but their business value.

Table 1: SafeConnect Asset Inventory

| Asset                  | Description                                                                                                                        | Business Value                                                                                    |
|------------------------|------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| User Database          | Stores personal profiles, photos, videos, activity data, and account credentials for all registered users                          | Very High; core product asset; loss triggers regulatory penalties and user trust collapse         |
| In-App Purchase System | Processes all financial transactions, stores payment-linked identifiers, and connects to third-party payment gateways              | Very High; direct revenue channel; compromise causes immediate financial loss and fraud liability |
| Source Code Repository | Contains the proprietary codebase including business logic, API keys, and configuration files                                      | High; exposure gives attackers a full map of the system's internals                               |
| Backend Infrastructure | Cloud servers, databases, load balancers, and storage systems that run the application                                             | High; availability attacks against these take the product offline                                 |
| API Layer              | The interface through which the mobile app communicates with backend services, including user data endpoints and payment callbacks | High; insecure API endpoints are one of the most exploited surfaces in mobile applications        |
| Authentication System  | Manages user identity, login sessions, tokens, and password reset flows                                                            | High; compromise here is the most direct path to mass account takeover                            |
| Media Storage          | Cloud storage holding user-uploaded photos and videos                                                                              | Medium; data exposure carries privacy and regulatory implications                                 |
| Brand and Reputation   | Public perception of SafeConnect's trustworthiness as a social platform                                                            | High; a breach at launch can permanently damage user acquisition prospects                        |

### 1.2 Threat Identification

#### External Threats (Malicious)

- Opportunistic attackers probing the API for injection points and authentication weaknesses
- Organized fraud groups targeting the payment processing module for financial theft
- Credential stuffing attacks using breached username/password lists from other platforms
- Distributed Denial of Service (DDoS) attacks aimed at disrupting app availability, particularly around launch
- Automated scrapers harvesting user profile data at scale for resale or social engineering campaigns

#### External Threats (Accidental)

- Third-party SDK or dependency introducing an unpatched vulnerability into the codebase
- Misconfigured cloud storage bucket publicly exposing user media or database snapshots

#### Internal Threats (Malicious)

- Disgruntled developer with repository access exfiltrating source code or database records before departure
- Insider with administrative credentials abusing access to extract user data for personal gain

#### Internal Threats (Accidental)

- Developer deploying untested code containing security flaws to production
- System administrator misconfiguring access controls, leaving sensitive endpoints exposed
- Employee falling for a phishing attack and handing over credentials with backend access

### 1.3 Vulnerability Identification

#### Technical Vulnerabilities

- Insufficient input validation across API endpoints, creating exposure to SQL injection and cross-site scripting
- Weak or absent rate limiting on authentication endpoints, enabling credential stuffing at scale
- Known vulnerability in the payment processing module, explicitly flagged in the client's threat data
- Absence of multi-factor authentication for user accounts and administrative panels
- Unencrypted sensitive data at rest or in transit between app components
- Overly permissive API access controls that do not enforce least-privilege per endpoint
- Lack of runtime application self-protection or API gateway throttling

#### Non-Technical Vulnerabilities

- No formal secure development lifecycle (SDLC), meaning security is not embedded in the build process
- Limited security awareness among development staff, particularly around social engineering
- Inadequate vendor security vetting for third-party SDKs and payment gateway integrations
- No documented incident response plan, which extends breach impact when one occurs
- Absence of a data classification policy, resulting in all data being handled with the same controls regardless of sensitivity

### 1.4 Risk Analysis (Qualitative)

Table 2: Qualitative Risk Register

| Risk ID | Risk Description                                                                                                 | Likelihood | Impact           | Risk Rating     | Score     |
|---------|------------------------------------------------------------------------------------------------------------------|------------|------------------|-----------------|-----------|
| R1      | Major Data Breach; external attacker exploits API or authentication weakness to extract the user database        | High (4)   | Catastrophic (5) | <b>CRITICAL</b> | <b>20</b> |
| R2      | Payment Fraud; attacker exploits the known payment module vulnerability for fraudulent transactions              | Medium (3) | Major (4)        | <b>HIGH</b>     | 12        |
| R3      | Account Takeover; credential stuffing compromises user accounts en masse due to weak authentication controls     | High (4)   | Moderate (3)     | <b>HIGH</b>     | 12        |
| R4      | DDoS Attack; coordinated availability attack takes SafeConnect offline during launch or peak periods             | Medium (3) | Major (4)        | <b>HIGH</b>     | 12        |
| R5      | Insider Data Theft; privileged developer or admin exfiltrates user data or source code                           | Low (2)    | Major (4)        | <b>MEDIUM</b>   | 8         |
| R6      | Insecure API Exposure; misconfigured or unprotected API endpoints allow unauthorized access to user records      | Medium (3) | Major (4)        | <b>HIGH</b>     | 12        |
| R7      | Regulatory Non-Compliance; insufficient data protection controls lead to GDPR/CCPA violations following a breach | Medium (3) | Major (4)        | <b>HIGH</b>     | 12        |

## 1.5 Risk Matrix (5x5)

The matrix below plots each identified risk by its Likelihood (rows, top to bottom: Very High to Very Low) and Impact (columns, left to right: Insignificant to Catastrophic). Each cell displays the risk score and, where a risk falls in that cell, its reference ID.

| LIKELIHOOD \ IMPACT | Insignificant(1) | Minor(2) | Moderate(3) | Major(4)               | Catastrophic(5) |
|---------------------|------------------|----------|-------------|------------------------|-----------------|
| Very High (5)       | 5                | 10       | 15          | 20                     | 25              |
| High (4)            | 4                | 8        | 12<br>R3    | 16                     | 20<br>R1        |
| Medium (3)          | 3                | 6        | 9           | 12<br>R2, R4<br>R6, R7 | 15              |
| Low (2)             | 2                | 4        | 6           | 8<br>R5                | 10              |
| Very Low (1)        | 1                | 2        | 3           | 4                      | 5               |

### Legend

|                         |                    |                     |                  |
|-------------------------|--------------------|---------------------|------------------|
| <b>CRITICAL (16-25)</b> | <b>HIGH (9-15)</b> | <b>MEDIUM (4-8)</b> | <b>LOW (1-3)</b> |
|-------------------------|--------------------|---------------------|------------------|

## 1.6 Risk Treatment Recommendations (Top Three Risks)

**R1: Major Data Breach | Score 20 (CRITICAL) | Treatment: MITIGATE**

The likelihood of a data breach is too high, and the financial and reputational consequences are too severe to accept or ignore. Mitigation is the only defensible response. The recommended controls are input validation hardening across all API endpoints, implementation of a Web Application Firewall, encryption of user data at rest and in transit, and adoption of a formal secure SDLC to catch vulnerabilities before they reach production. These controls directly reduce the probability of exploitation and limit the blast radius if a breach does occur. A cyber insurance policy should also be purchased to transfer residual financial exposure, making this a combined mitigate-and-transfer strategy.

**R2: Payment Fraud | Score 12 (HIGH) | Treatment: MITIGATE**

A known vulnerability in the payment processing module is not a theoretical risk. It is a documented weakness in a revenue-generating asset. Immediate code remediation is required. Supplementary controls should include input validation on all transaction endpoints, tokenization of payment data so raw card details never touch SafeConnect's servers, transaction velocity monitoring to detect anomalous patterns, and regular third-party code audits of the payment flow. Transferring some residual fraud liability to the payment gateway provider through contractual terms is also worth pursuing.

**R4: DDoS Attack | Score 12 (HIGH) | Treatment: MITIGATE AND TRANSFER**

A DDoS attack at or around the app launch could be catastrophic to user acquisition and investor confidence, even if no data is lost. The recommended mitigation is deploying a CDN with built-in DDoS protection, implementing API rate limiting and traffic throttling, and configuring auto-scaling cloud infrastructure to absorb traffic spikes. Because DDoS mitigation has a cost ceiling and residual risk always remains, the financial impact of prolonged downtime should be addressed through business interruption coverage under a cyber insurance policy.

## Quantitative Risk Assessment

### 2.1 Single Loss Expectancy (SLE)

**Formula:**  $SLE = Asset\ Value\ (AV) \times Exposure\ Factor\ (EF)$

**a. Major Data Breach (User Database)**

| Variable             | Value                                   | Notes                                                                             |
|----------------------|-----------------------------------------|-----------------------------------------------------------------------------------|
| Asset Value (AV)     | \$3,500,000                             | Includes development cost, user acquisition cost, and projected revenue           |
| Exposure Factor (EF) | 0.40 (40%)                              | Estimated loss from regulatory fines, notification costs, and reputational damage |
| $SLE = AV \times EF$ | $\$3,500,000 \times 0.40 = \$1,400,000$ | Total expected loss from a single data breach event                               |

A single successful breach of the user database is expected to cost Safempire Inc. \$1,400,000 in regulatory fines, notification costs, and reputational losses.

**b. Payment Fraud (In-App Purchase System)**

| Variable             | Value                          | Notes                                                              |
|----------------------|--------------------------------|--------------------------------------------------------------------|
| Asset Value (AV)     | \$1,500,000                    | Value of the in-app purchase system                                |
| Exposure Factor (EF) | 0.10 (10%)                     | Estimated loss from fraudulent transactions per exploitation event |
| SLE = AV x EF        | \$1,500,000 x 0.10 = \$150,000 | Total expected loss from a single payment fraud event              |

A single exploitation of the payment fraud vulnerability is expected to result in \$150,000 in direct financial loss.

**2.2 Annualized Loss Expectancy (ALE) Before Control**

Formula: **ALE = SLE x Annualized Rate of Occurrence (ARO)**

| Risk                 | SLE         | ARO                       | ALE (SLE x ARO)  | Notes                                                |
|----------------------|-------------|---------------------------|------------------|------------------------------------------------------|
| a. Major Data Breach | \$1,400,000 | 0.25 (once every 4 years) | <b>\$350,000</b> | 25% annual probability per industry data             |
| b. Payment Fraud     | \$150,000   | 0.50 (once every 2 years) | <b>\$75,000</b>  | Specific vulnerability identified in payment module  |
| c. Total Current ALE |             |                           | <b>\$425,000</b> | Combined annual cyber risk exposure without controls |

Without the proposed security control, Safempire Inc. is carrying a combined annualized cyber risk exposure of \$425,000.

**2.3 Cost-Benefit Analysis and ROSI**

**Proposed Control:** WAF, regular code audits, and employee security training | **Annual Cost:** \$75,000

**Control Effect:** Reduces data breach ARO from 0.25 to 0.10; reduces payment fraud ARO from 0.50 to 0.10

**a. New ALE After Control Is Implemented**

| Risk          | SLE         | New ARO | New ALE (SLE x New ARO) | ALE Reduction                           |
|---------------|-------------|---------|-------------------------|-----------------------------------------|
| Data Breach   | \$1,400,000 | 0.10    | \$140,000               | \$350,000 - \$140,000 = \$210,000 saved |
| Payment Fraud | \$150,000   | 0.10    | \$15,000                | \$75,000 - \$15,000 = \$60,000 saved    |
| Total New ALE |             |         | <b>\$155,000</b>        | <b>\$270,000 total saved annually</b>   |

## b. Return on Security Investment (ROSI)

**Formula:**  $ROSI = (ALE \text{ Before Control} - ALE \text{ After Control} - \text{Annual Cost of Control}) / \text{Annual Cost of Control}$

| Step                 | Calculation                                           | Result             |
|----------------------|-------------------------------------------------------|--------------------|
| Step 1: Loss Avoided | ALE Before - ALE After = \$425,000 - \$155,000        | \$270,000          |
| Step 2: Net Benefit  | Loss Avoided - Cost of Control = \$270,000 - \$75,000 | \$195,000          |
| Step 3: ROSI         | Net Benefit / Cost of Control = \$195,000 / \$75,000  | <b>2.6 or 260%</b> |

For every dollar invested in the proposed security control package, Safempire Inc. recovers \$2.60 in averted losses. The control pays for itself more than two-and-a-half times over in its first year.

## Recommendation to the CEO

**To:** Chief Executive Officer, Safempire Inc.

**Re:** Investment Decision: Proposed Security Control Package (\$75,000/year)

The numbers make this an easy call. SafeConnect currently carries a combined annual cyber risk exposure of \$425,000 across its two most financially significant threats: a major data breach of the user database and exploitation of the known payment fraud vulnerability. The proposed security package, which includes a Web Application Firewall, regular code audits, and employee security training at a total annual cost of \$75,000, reduces that exposure to \$155,000 per year. That is a savings of \$270,000 in averted losses annually, translating to a ROSI of 260%. Every dollar invested returns \$2.60. Beyond the numbers, a breach during or shortly after launch would carry consequences that no financial model fully captures: loss of early user trust, negative press coverage, and potential regulatory scrutiny at exactly the moment the company needs momentum. The recommendation is to approve this investment without delay, and to treat it as a condition of bringing a social networking product to market responsibly.

## Summary of Quantitative Findings

| Metric                               | Value            |
|--------------------------------------|------------------|
| SLE — Major Data Breach              | \$1,400,000      |
| SLE — Payment Fraud                  | \$150,000        |
| ALE (Data Breach) Before Control     | \$350,000        |
| ALE (Payment Fraud) Before Control   | \$75,000         |
| Total ALE Before Control             | <b>\$425,000</b> |
| ALE (Data Breach) After Control      | \$140,000        |
| ALE (Payment Fraud) After Control    | \$15,000         |
| Total ALE After Control              | <b>\$155,000</b> |
| Annual Cost of Proposed Control      | \$75,000         |
| Annual Loss Avoided                  | <b>\$270,000</b> |
| Return on Security Investment (ROSI) | <b>260%</b>      |